

모의해킹 상세 보고서

과업명	유기건 성향 분석 기반 추천 서비스 구축 사업 및 정보보호 체계 강화사업
-----	---

2026년 07월 16일

개 정 이 력

[illegible]

내용

1. 모의해킹 수행 정보	4
1.1. 배경 및 목적	4
1.2. 수행 일정 및 수행 내역	4
1.3. 수행 대상	5
1.6. 점검 도구	5
2. 모의해킹 결과	5
2.1. 총평	5
2.2 결과 요약	6
3. 취약점 상세 내용.....	7
3.1. XSS (댓글 등록)	7
3.2. IDOR (멍! 케어 수정 / 멍! 카이브 수정 / 멍! 로그 수정).....	9
3.3. File Upload(보호소 회원 인증 파일 등록).....	11
4. 보안 권고안.....	15
4.1. XSS (댓글 등록)	15
4.2 IDOR (데이터 수정).....	15
4.3 File Upload.....	15

1. 모의해킹 수행 정보

1.1. 배경 및 목적

- 웹 애플리케이션에 대한 모의 해킹을 수행한 후 발견된 취약점에 대한 대응 방안을 제시함으로써 차후 발생할 수 있는 침해 사고를 예방하고 정보 보호 수준을 향상할 수 있는 대책을 수립하는 데 기여하는 것을 목적으로 합니다.
- 본 사업은 유기견 입양 추천 서비스의 안정적인 운영환경 구축 및 보안 강화를 위해 모의해킹을 수행하는 것을 목적으로 합니다.
 - **선제적 취약점 도출:** 실제 해커 관점의 시나리오 기반 모의해킹을 통해 서비스 및 인프라의 잠재적 보안 취약점 식별
 - **침해사고 예방 및 대응력 강화:** 식별된 취약점에 대한 실효성 있는 보안 대책(Patch)을 수립하여 외부 위협으로부터 시스템 보호
 - **안전한 서비스 환경 확보:** 사용자 개인정보 보호 체계를 공고히 하고, 중단 없는 안정적인 유기견 입양 추천 서비스 환경 구축

1.2. 수행 일정 및 수행 내역

NO	수행 날짜	수행 내역
1	26.07.03	SQL Injection
2	26.07.05	IDOR(주문정보조회)
3	26.07.05	IDOR(장바구니 수량 변경)
4	26.07.06	IDOR(마이페이지 정보 변경)
5	26.07.07	Session Fixation
6	26.07.07	Web Shell(상품 등록)
7	26.07.08	CSRF(마이페이지)

1.3. 수행 대상

NO	페이지	사이트명(URL)
1	로그인	http://www.ddd.com/user/login.us
2	멍! 로그 댓글	http://www.ddd.com/comment/writeOk.lo
3	관리자	http://www.ddd.com/admin/InquiryDetailOk.ad
4	1:1 문의페이지	http://www.ddd.com/inquiry/inquiryReadOk.in
5	멍! 로그 수정	http://www.ddd.com/log/update.lo
6	멍! 케어 수정	http://www.ddd.com/care/update.ca
7	멍! 카이브 수정	http://www.ddd.com/archive/update.ar
8	멍! 로그 작성	http://www.ddd.com/log/write.lo
9	멍! 카이브 작성	http://www.ddd.com/archive/write.ar
10	마이페이지	http://www.ddd.com/mypage/profileEditS.mp

1.6. 점검 도구

○ 본 모의해킹을 수행하면서 사용된 도구는 아래 표와 같다.

도구 이름	용도	사이트
Burp Suite	프록시	http://portswigger.net/Burp/

2. 모의해킹 결과

2.1. 총평

- 본 시스템은 게시판에 4개, 문의게시판에 1개, 댓글에 1개, 마이페이지에 1개 총 6개의 취약점이 존재합니다.
- 크로스 사이트 스크립팅, IDOR, File Upload 등의 취약점이 존재하며, 크로스 사이트 스크립팅 취약점으로는 사용자 세션 쿠키 탈취, 피싱 사이트 강제 이동 공격 위험, IDOR 취약점으로는 데이터 무결성 훼손 공격 위험, File Upload 취약점으로는 서버 검증 우회 웹 셸 공격 위험이 있음

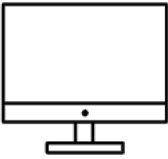
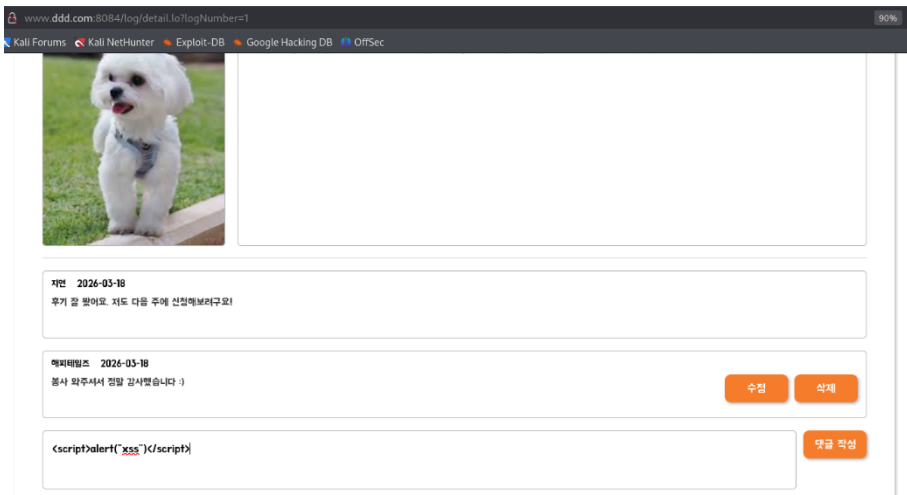
니다.

2.2 결과 요약

NO	대상	취약점	위치	점검 상태
1	로그인	세션고정 SQL Injection	http://www.ddd.com/user/login.us	양호
2	멍! 로그 댓글	XSS	http://www.ddd.com/comment/writeOk.lo	취약
3	관리자 문의답변페이지	XSS	http://www.ddd.com/admin/InquiryDetailOk.ad	취약
4	1:1 문의페이지	XSS	http://www.ddd.com/inquiry/inquiryReadOk.in	취약
5	멍! 로그 수정	IDOR	http://www.ddd.com/log/update.lo	양호
6	멍! 케어 수정	IDOR	http://www.ddd.com/care/update.ca	취약
7	멍! 카이브 수정	IDOR	http://www.ddd.com/archive/update.ar	취약
8	멍! 로그 작성	File Upload	http://www.ddd.com/log/write.lo	양호
9	멍! 카이브 작성	File Upload	http://www.ddd.com/archive/write.ar	양호
10	마이페이지 보호소회원 정보변경	File Upload	http://www.ddd.com/mypage/profileEditS.mp	취약

3. 취약점 상세 내용

3.1. XSS (댓글 등록)

구분	설명		
발견URL	URL	파라미터	메뉴
	http://www.ddd.com/comment/writeOk.lo	commentPost	댓글 등록
취약점 상세내역	댓글 등록 시 입력되는 commentPost 데이터에 대한 출력 단계에서의 인코딩 처리 부재 또는 입력 단계에서의 특수문자 필터링 미흡해 <script>alert('xss')</script>와 같은 스크립트 코드를 입력하고 전송이 가능합니다.		
시나리오	악성 스크립트 코드 등록   →  악성 스크립트 실행  →  공격자 DataBase 사용자 화면		
재현 절차	1. 멍! 로그 상세페이지에서 악성 스크립트로 댓글 작성 공격자가 로그인 후 멍! 로그 상세페이지에 접근해 악성 스크립트로 댓글을 등록한다  그림 3.1-1. 멍! 로그 상세페이지에서 악성 스크립트로 댓글 작성		

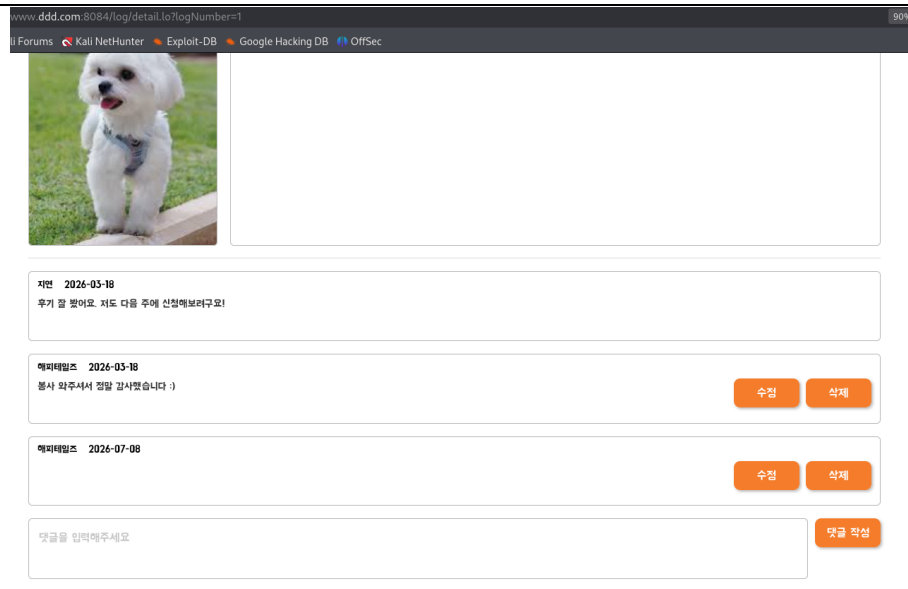


그림 3.1-2. 댓글 등록 후 모습

2. 타 회원으로 해당 멍! 로그 상세페이지 접근

타 회원으로 악성 스크립트가 등록된 멍! 로그 상세페이지로 접근하게 되면 스크립트 내용이 실행되는 모습이다.

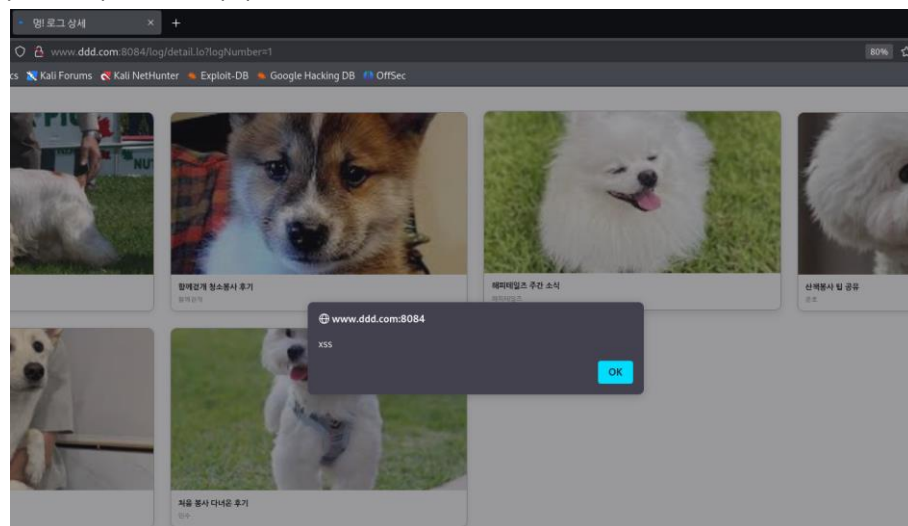
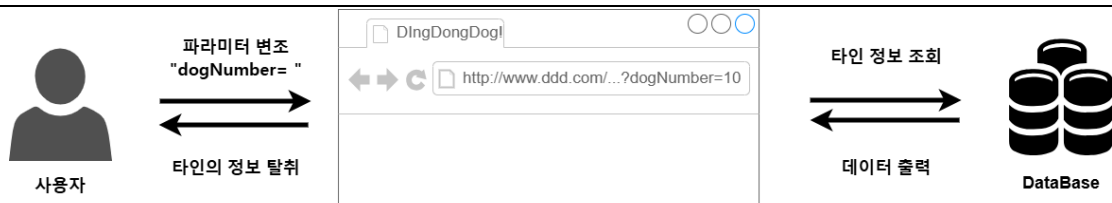


그림 3.1-3. 스크립트 실행되는 화면

영향도	영향	설명
	사용자 리다이렉션 (Phishing)	피해자를 공격자가 미리 만들어 둔 악성 피싱 사이트로 강제 이동시켜 개인정보 탈취를 시도할 수 있음

	페이지 변조 (Defacement)	댓글 조회 시 강제로 특정 HTML 요소를 변경하여 웹 사이트의 신뢰도를 떨어뜨리거나, 허위 정보를 게시하여 사용자의 혼란을 야기함
발생 원인	원인	설명
	입력 값 검증 부재	서버가 댓글 입력 값(commentPost)을 DB에 저장할 때, <script>, <iframe>, onmouseover와 같은 악성 태그나 이벤트 핸들러가 포함되어 있는지 검사하는 로직(블랙리스트 기반 필터링)이 전무
	출력 값 이스케이프 미흡	저장된 데이터를 브라우저에 출력하는 단계에서, 특수문자(<, >, &, ', ")를 HTML 엔티티 코드로 변환하는 처리 과정이 수행되지 않아, 브라우저가 이를 문자열이 아닌 명령어로 인식하게 됨

3.2. IDOR (멍! 케어 수정 / 멍! 카이브 수정 / 멍! 로그 수정)

구분	설명		
발견URL	URL	파라미터	메뉴
	http://www.ddd.com/log/update.lo http://www.ddd.com/care/update.ca http://www.ddd.com/archive/update.ar	logNumber careNumber dogNumber	각 게시판 수정페이지
취약점 상세내역	수정 페이지에 접근할 때, 서버가 "현재 요청을 보낸 사용자가 해당 데이터의 실제 소유자인가?"를 검증하지 않고, 오직 URL의 파라미터(숫자 ID)만 확인하여 수정 페이지를 보여주기 때문입니다.		
시나리오	 사용자 파라미터 변조 "dogNumber=" 타인의 정보 탈취 타인 정보 조회 데이터 출력 DataBase		
재현 절차	1. 보호소 회원의 멍! 카이브 등록 정보		

멍! 카이브 등록 정보

f	l	oo	^^
f f	l l	oo f	^^ f
			
호주 스피츠	나나 치와와	반어 멜리코가비스	

1

그림 3.2-1. 보호소 회원의 멍! 카이브 등록 정보

2. 해당 보호소 회원의 멍! 카이브 수정페이지

해당 세션으로 정상적으로 본인의 멍! 카이브 수정페이지에 접근하였다.

멍! 카이브 수정
www.ddd.com:3064/archive/update.ar?dogNumber=1

Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec
80%

1. 반려견, 입양독?
소개 멍! 매칭 멍! 로그 멍!케어 멍! 카이브
블루포우닝
영인합니다

멍! 카이브 수정



아래로 보기

이름 : 나나

품종 : 치와와

성별 : F

나이 : 2살

몸무게 : 3.0

보호 시작일 : 02 / 07 / 2026

활동성 : 3 점수: 3점

사회성 : 3 점수: 3점

독립성 : 3 점수: 3점

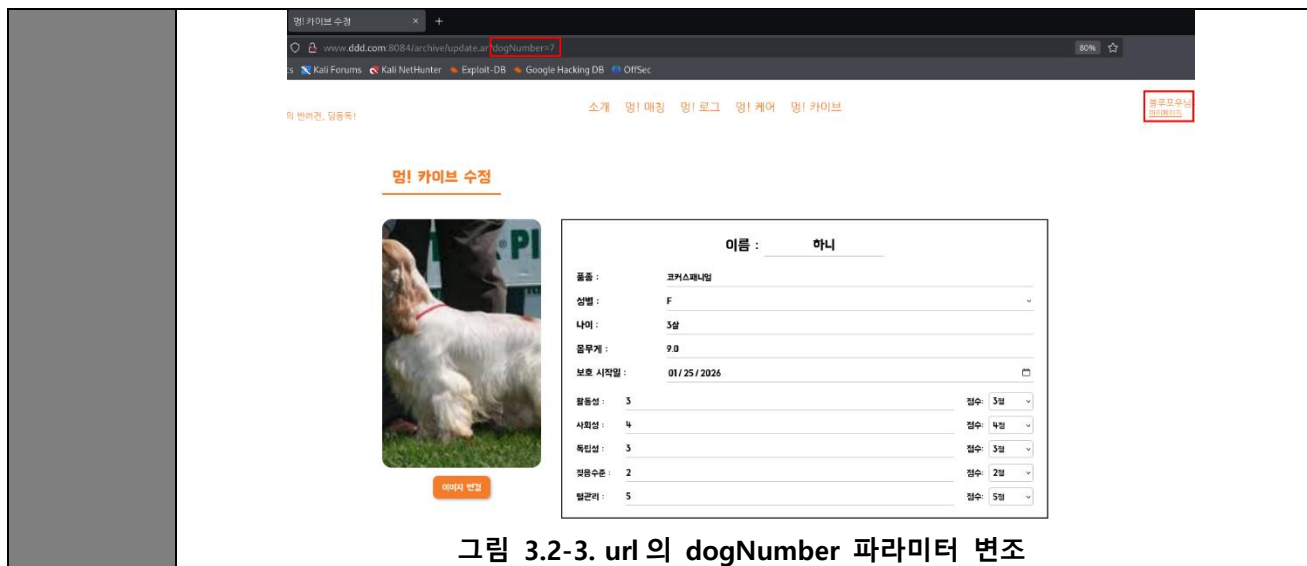
정음수준 : 4 점수: 4점

털관리 : 2 점수: 2점

그림 3.2-2. 해당 보호소 회원의 멍! 카이브 수정페이지

3. url의 dogNumber 파라미터 변조

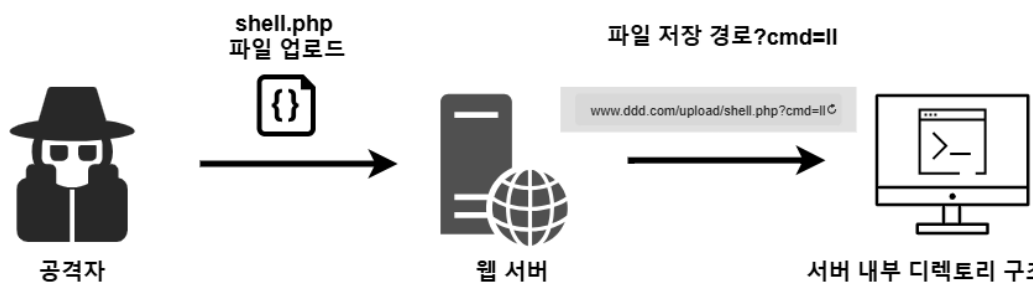
url에 dogNumber를 타 회원이 소유한 dogNumber로 변조한 후 접근하면 정상적으로 접근이 가능한 모습이다.



영향도	영향	설명
	비인가 데이터 수정 및 변조	타인의 게시글, 후기, 혹은 보호소의 소중한 정보를 무단으로 수정하거나 삭제하여 데이터의 무결성을 훼손함
	신뢰도 하락	개인정보를 포함한 게시글이 타인에게 노출 및 수정될 가능성이 있으므로, 사용자들에게 서비스에 대한 신뢰를 잃게 함
발생 원인	원인	설명
	소유권 검증 로직 부재	서버 측에서 데이터 수정 요청을 받을 때, 현재 로그인한 사용자의 세션 정보와 요청된 객체(게시글/주문 번호 등)의 실제 소유주를 대조하는 검증 과정을 생략함
	파라미터 직접 참조 허용	URL 파라미터로 넘어오는 식별자(ID) 값을 별도의 인가 절차 없이 데이터베이스 조회 쿼리의 조건문(WHERE 절)에 직접 결합하여 사용함

3.3. File Upload(보호소 회원 인증 파일 등록)

구분	설명		
발견URL	URL	파라미터	메뉴
	http://www.ddd.com/mypage/	file_original_name	보호소 회원

	profileEditS.mp		정보수정페이지
취약점 상세내역	사용자가 프로필 이미지를 업로드할 때, 서버가 파일의 확장자나 MIME 타입을 적절히 검증하지 않아 악성 스크립트(웹 쉘)를 포함한 실행 파일이 서버에 저장되고 실행될 수 있는 취약점입니다.		
시나리오	 공격자 → 웹 서버 → 서버 내부 디렉토리 구조 유출		
재현 절차	1. 파일 업로드 보호소 회원의 정보변경 페이지에서 보호소 인증 파일에 shell.php 파일을 업로드한다. 내 정보 변경 아이디 변경 할 비밀번호 비밀번호 재확인 보호소명 닉네임 이메일 주소 핸드폰 번호 인증 번호 보호소 인증 happy_shelter a a happy@ddd.com 010-5000-0005 필문, 숫자, 특수문자 포함 할때가 이상 특수문자 제외 20자 이내로 입력해주세요. Browse... shell.php 중복확인 인증 번호 전송 인증 번호 확인 변경 완료 파일등록 그림 3.3-1. 파일 업로드 2. 관리자페이지 보호소 회원 정보 확인 관리자페이지 보호소 회원 정보에서도 문서/이미지 파일 이외에 다른 확장자 파일이 업로드 된 것을 확인 가능하다.		

아이디	happy_shelter
이름	a
보호소명	a
닉네임	a
주소	1
사업자등록번호	1
첨부파일	shell.php 다운로드

그림 3.3-2. 관리자페이지 보호소 회원 정보 확인

3. 악성 코드 파일 경로로 cmd 명령어 실행

악성 파일 경로로 접근해서 cmd 명령어를 통해 내부 디렉터리 구조를 확인할 수 있다.

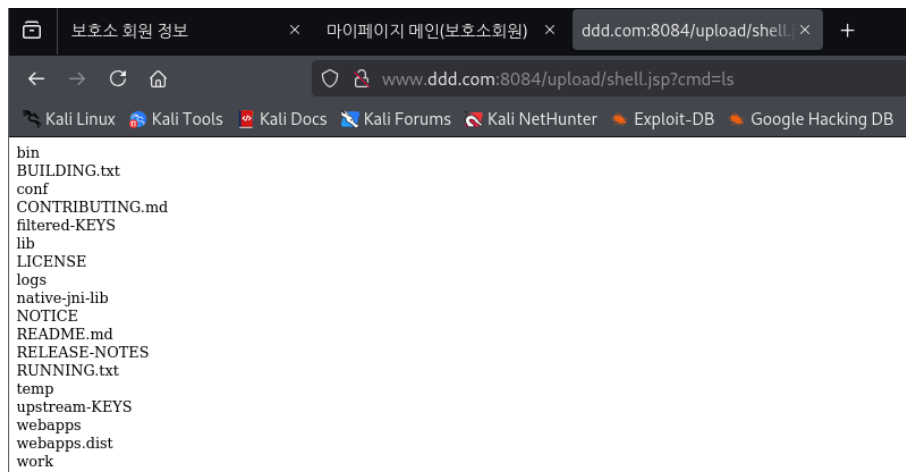


그림 3.3-3. 악성 코드 파일 경로로 cmd 명령어 실행

영향도	영향	설명
	데이터 무결성 훼손	DB 데이터 유출, 변조, 서비스 중단 등 서버 내부의 모든 자산이 공격자에게 노출됨
	서버 완전 장악	공격자가 서버 내 임의의 명령어를 실행하여 시스템 정보를 탈취하거나, 서버를 악성코드 유포지로 이용함
	측면 이동	웹 서버를 발판으로 내부 네트워크의 다른

		서버(DB 서버 등)로 침투를 시도하는 거점으로 악용됨
발생 원인	원인	설명
	파일 확장자 검증 미흡	업로드 되는 파일의 확장자가 이미지 파일인지 확인하는 화이트리스트 필터링 로직이 존재하지 않거나, 블랙리스트를 우회할 수 있는 이중 확장자나 대소문자 혼용 공격을 차단하지 못함
	MIME 타입 검증 부재	파일의 실제 내용을 검사하지 않고 클라이언트가 전송한 Content-Type 헤더 값만을 신뢰하여 저장함
	서버 실행 권한 설정 오류	웹 서버의 업로드 디렉토리에 PHP 파일 실행 권한이 부여되어 있어, 업로드 된 웹 셸이 브라우저 호출을 통해 서버에서 명령어로 실행됨

4. 보안 권고안

4.1. XSS (댓글 등록)

취약점 항목	XSS (Cross-Site Scripting)
취약점 개요	입력 값에 대한 필터링 및 출력 값에 대한 인코딩 처리가 미흡할 경우, 악성 스크립트가 삽입되어 피해자의 브라우저에서 실행됨으로써 쿠키 탈취, 피싱, 페이지 변조 등의 공격이 가능함
보안 조치 방법	
1. 입력 값 검증: 사용자로부터 입력 받는 모든 데이터에 대해 <script>, <iframe>, onmouseover 등의 위험한 태그 및 이벤트 핸들러가 포함되어 있는지 검사(화이트리스트 방식 권장)	
2. 출력 값 인코딩(Escaping): 데이터를 브라우저에 출력할 때 특수문자(<, >, &, ', ")를 HTML 엔티티 코드로 변환하여 브라우저가 스크립트로 해석하지 않고 단순 문자열로 처리하도록 구현	

4.2 IDOR (데이터 수정)

취약점 항목	IDOR (Insecure Direct Object Reference)
취약점 개요	데이터 수정 요청 시, 서버가 해당 자원에 대한 사용자의 권한을 검증하지 않고 파라미터(ID) 값만으로 처리를 수행하여, 타인의 데이터를 무단으로 조회, 수정, 삭제할 수 있는 취약점
보안 조치 방법	
1. 소유권 검증 로직 구현: 데이터 수정/조회 요청 시, 세션에 저장된 현재 로그인 사용자의 정보(User ID)와 수정하려는 자원의 소유주(Owner ID)가 일치하는지 서버 측에서 반드시 검증	
2. 간접 참조 식별자 사용: 데이터베이스의 기본 키(PK) 값을 직접 노출하지 말고, 매핑된 무작위 값(UUID 등)을 사용하여 식별자가 직접 추측되지 않도록 설계	

4.3 File Upload

취약점 항목	File Upload (Arbitrary File Upload)
취약점 개요	파일 업로드 시 확장자나 파일 내용에 대한 검증이 미흡할 경우, 웹 셸(Web Shell)과 같은 악성 실행 파일이 서버에 저장 및 실행되어 시스템 제어권을 탈취당할 수 있는 위험
보안 조치 방법	
1. 확장자 화이트리스트 제한: 허용된 확장자(예: jpg, png 등) 외에는 업로드를 원천 차단하며, 서버 내에서 파일의 실제 MIME 타입을 검사	

2. 파일명 재정의: 업로드 되는 파일명은 시스템에서 무작위로 생성하여 사용하고, 기존 파일명은 DB 에 별도 저장하여 경로 탐색 공격 방지
3. 실행 권한 제한: 업로드 디렉토리에 대한 웹 서버의 실행 권한(Execute Permission)을 제거하고, 파일을 별도의 물리적 서버나 외부 스토리지에 저장하여 직접 실행 방지